STOQ-X1-POL-004

Bounded standing delegation of X1 approval automation authority

Version: 1.0 draft
Policy date: 2026-08-31
Status: `DRAFT_UNSIGNED - NOT EFFECTIVE`
Effect: None until all required authorities, identities, references, validity dates and signatures are completed and verified
Classification: Internal control policy draft
Technical scope: X1 Finance/Accounting table remediation, non-production authenticated evidence and deterministic technical-gate evaluation

> This is a governance draft for review and signature through the organization's authoritative approval workflow. It is not legal advice, an electronic signature, a production authorization, or evidence that any named candidate currently holds the required formal authority.

1. Purpose

This policy establishes a bounded standing delegation under which a named automation service principal may create approval records, retrieve approved control facts and issue machine attestations for the X1 non-production technical workflow.

The delegation applies only to deterministic decisions whose criteria, scope, expiry, contract version and evidence requirements are fixed by this signed policy and its referenced immutable artifacts.

The automation acts under its own non-human identity. It must never impersonate a person, create a human signature, infer consent or exercise discretion reserved to a human authority.

2. Referenced technical contract

Field	Value
X1 contract artifact URI	`repository://stoquify/docs/blockers-docs/X1_CONTRACT_ARTIFACT_MANIFEST_2026-08-31.json`
X1 contract manifest SHA-256	`cdb16e90a74ea942e204bc8191445041a9810285061936309678 6768e777c9e4`
Contract scope	Canonical table contract, Finance/Accounting archetype contract, next-phase normalization/scale contract and X1 approval/evidence binding
Contract version	X1 evidence binding schema version 1; budget contract version 1
Authorized environment	`[HUMAN INPUT REQUIRED: exact non-production environment/origin]`

Field	Value
Authorized fixture database	`stoquify_replay_next_20260830` technical candidate; `[HUMAN AUTHORIZATION REQUIRED]`
Authorized tenant	`rds_org_001` technical candidate; `[HUMAN AUTHORIZATION REQUIRED]`
Foreign isolation probe tenant	`rds_org_002` technical candidate; `[HUMAN AUTHORIZATION REQUIRED]`

3. Database-reconciled identity candidates

These entries establish technical identity only. They do not establish formal appointment or signing authority.

Responsibility	Candidate	Technical identifier	Authority status
Product/budget authority	Kouatchoua Mark	`rds_org_001_compliance_user_product_approver`	Candidate only; appointment reference required
Security/control authority	Yonga Springfield	`rds_org_001_compliance_user_security_owner`	Candidate only; appointment reference required
Managed-secrets accountability	Ronald Djakou	`rds_org_001_compliance_user_sre_owner`	Approximate candidate only; exact appointment required
Fixture-data/tenant accountability	Mireille Nkoa	`rds_org_001_compliance_user_owner`	Approximate candidate only; exact appointment required
Independent release authority	Sonkeng Steve	`rds_org_001_compliance_user_qa_owner`	Candidate only; independence and appointment required
External-accountant evidence persona	Carine Manga	`rds_org_001_compliance_user_external_accountant`	Exact technical persona candidate; credential-use approval required

4. Authority granted to automation

After activation, the named approval-orchestration service principal may:

1. Create draft records in the authoritative approval system and retrieve their immutable record IDs.
2. Retrieve approved user, role, tenant, entitlement, redaction, retention, environment and authority-reference metadata from authoritative systems.
3. Populate controlled templates with non-secret values and exact artifact references.
4. Calculate SHA-256 hashes and reject any artifact that does not match the signed contract or approved CI binding.
5. Evaluate the deterministic rules in Section 7.
6. Issue a machine attestation of `AUTO_APPROVED_WITHIN_DELEGATION` only when every mandatory condition passes.
7. Issue `BLOCKED_REQUIRES_HUMAN_DECISION` when any condition fails, is absent, is ambiguous, is expired or requires judgment.
8. Create remediation and audit records without modifying source evidence or service-owned business truth.

9. Revoke or suspend its own delegated workflow when expiry, revocation, identity compromise or control failure is detected.

5. Authority explicitly not granted

Automation may not:

- Sign or impersonate a human.
- Appoint an authority or infer that an application role is a formal appointment.
- Set or change product budgets, acceptance thresholds, redaction rules or retention periods.
- Waive a failed control, accessibility issue, segregation conflict, tenant-isolation failure or missing evidence.
- Accept residual risk.
- Authorize production, deployment, customer exposure or data migration.
- Reset, reseed or destructively modify an existing populated database.
- Change users, RBAC, module entitlements, tenant boundaries or protected actions.
- Retrieve, print, store or publish a password, token, cookie, private key, connection string or browser storage state.
- Post, reverse, void, approve or alter service-owned accounting, payroll, HRIS, inventory, purchasing or payment truth.
- Issue legal, tax, statutory, accounting, security, privacy, accessibility or release certification.
- Approve an exception to this policy.

6. Required service identities and segregation

Identity	Required value	Separation requirement
Approval-orchestration service principal	`[HUMAN INPUT REQUIRED: immutable non-human object ID]`	May create/retrieve approval records; cannot sign as a human
Evidence-capture service principal	`[HUMAN INPUT REQUIRED: immutable non-human object ID]`	May run bounded authenticated evidence; cannot promote the gate
Independent-verifier service principal	`[HUMAN INPUT REQUIRED: immutable non-human object ID]`	May evaluate immutable evidence; must be distinct from implementation and capture
Implementation/CI service principal	`[HUMAN INPUT REQUIRED: immutable non-human object ID]`	May build/test; cannot independently verify or approve its own output

All credentials must be referenced through an approved secret manager using workload identity. No secret value may appear in this policy, a report, source control or an evidence artifact.

7. Deterministic decision rules

Automation may issue `AUTO_APPROVED_WITHIN_DELEGATION` only when all of the following are true:

1. This policy is signed, active, unexpired, unrevoked and hash-valid.
2. Every signer is bound to a verified immutable directory ID and a valid authority-appointment reference covering the signed scope.

3. The X1 contract URI, contract hash, CI commit, fixture manifest, database and tenant IDs match the signed scope exactly.
4. The approval, evidence-capture and verifier service identities are active, least-privileged and segregated.
5. Finance and Accounting module entitlement is authoritatively approved for the exact tenant.
6. The external-accountant persona is the approved user and has all required read/export permissions and none of the forbidden mutation permissions.
7. The exact non-production origin, secret reference, seeded data, tenant and foreign isolation probe are approved and within their validity periods.
8. All focused contract, authorization, redaction, export and integrity tests pass on the bound commit.
9. All required authenticated EN/FR desktop, tablet and mobile evidence artifacts exist, are file-backed, hash-valid, current and secret-scan clean.
10. Tenant isolation, protected-action absence, server-side export authorization and redaction all pass.
11. No serious or critical accessibility finding, clipped required control or unusable keyboard focus remains.
12. All mandatory performance signals defined by the signed product-budget policy pass; measurement-only signals remain explicitly non-gating.
13. Temporary authentication state is deleted and complete audit events are retained.

If any rule is false, missing, expired, revoked, inconclusive or not machine-verifiable, the only permitted output is `BLOCKED_REQUIRES_HUMAN_DECISION`.

8. Approval record and machine attestation requirements

Every automated decision must retain:

- Unique immutable decision and run IDs.
- Service-principal object ID and credential provenance without secret material.
- Delegation policy ID, version, hash, effective time and expiry time.
- Approval-system parent and child record IDs.
- Contract URI, contract hash and exact CI commit SHA.
- Database, fixture-manifest and tenant identifiers.
- Input evidence manifest and individual artifact hashes.
- Rule-by-rule results with stable reason codes.
- Decision, timestamp and any escalation reference.
- Tamper-evident audit-store URI and retention-policy ID.

The machine attestation must say **machine decision under standing delegation**. It must not be represented as a human signature.

9. Validity, suspension and revocation

Field	Required entry
Effective from	`[HUMAN INPUT REQUIRED: ISO-8601 timestamp]`
Expires at	`[HUMAN INPUT REQUIRED: ISO-8601 timestamp; maximum approved period]`
Maximum automated decision lifetime	`[HUMAN INPUT REQUIRED: hours/days, not beyond policy expiry]`

Field	Required entry
Revocation authority	`[HUMAN INPUT REQUIRED: name, immutable directory ID and appointment reference]`
Revocation mechanism	`[HUMAN INPUT REQUIRED: approval-system action/API and emergency suspension procedure]`
Review frequency	`[HUMAN INPUT REQUIRED: recommended at least quarterly and after any contract/control change]`

Revocation, expiry, contract mismatch, signer-authority expiry, identity compromise, evidence-store failure or audit failure must suspend automation immediately and fail closed.

10. Required signing model

Option A: single umbrella-authority signer

One person may sign only when an immutable authority instrument expressly permits that person to delegate all product-budget, security/credential, fixture-data and independent technical-release scopes covered here.

Field	Entry
Umbrella authority full name	`[HUMAN INPUT REQUIRED]`
Immutable directory/user ID	`[HUMAN INPUT REQUIRED]`
Authority instrument ID and URI	`[HUMAN INPUT REQUIRED]`
Scope verification	`[HUMAN INPUT REQUIRED: exact clauses covering every delegated scope]`

If this authority cannot be proven, Option B is mandatory.

Option B: separate co-signers — recommended

Required signer	Full name and immutable ID	Authority appointment reference	Decision	Signature/envelope reference	Signed at
Product/budget authority	`[HUMAN INPUT REQUIRED]`	`[HUMAN INPUT REQUIRED]`	`[APPROVE / REJECT / REVISE]`	`[HUMAN INPUT REQUIRED]`	`[ISO-8601]`
Security/control authority	`[HUMAN INPUT REQUIRED]`	`[HUMAN INPUT REQUIRED]`	`[APPROVE / REJECT / REVISE]`	`[HUMAN INPUT REQUIRED]`	`[ISO-8601]`
Managed-secrets authority	`[HUMAN INPUT REQUIRED]`	`[HUMAN INPUT REQUIRED]`	`[APPROVE / REJECT / REVISE]`	`[HUMAN INPUT REQUIRED]`	`[ISO-8601]`
Fixture-data/tenant authority	`[HUMAN INPUT REQUIRED]`	`[HUMAN INPUT REQUIRED]`	`[APPROVE / REJECT / REVISE]`	`[HUMAN INPUT REQUIRED]`	`[ISO-8601]`
Independent release authority	`[HUMAN INPUT REQUIRED]`	`[HUMAN INPUT REQUIRED]`	`[APPROVE / REJECT / REVISE]`	`[HUMAN INPUT REQUIRED]`	`[ISO-8601]`

One person may occupy multiple rows only when the authority register expressly permits it and the independent-release requirement is not compromised.

11. Final activation record

Complete these fields in the authoritative approval system before activation:

Field	Entry
Approval-system record ID	`[HUMAN INPUT REQUIRED: immutable record ID]`
Signature workflow/envelope ID	`[HUMAN INPUT REQUIRED: preallocated immutable ID]`
Final decision	`[HUMAN INPUT REQUIRED: APPROVE / REJECT / REVISE]`
Policy Markdown artifact URI	`repository://stoquify/docs/blockers-docs/STOQ-X1-POL-004_BOUNDED_AUTOMATION_AUTHORITY_DELEGATION_DRAFT_2026-08-31.md`
Policy PDF artifact URI	`repository://stoquify/docs/blockers-docs/STOQ-X1-POL-004_BOUNDED_AUTOMATION_AUTHORITY_DELEGATION_DRAFT_2026-08-31.pdf`
Final artifact hashes	Recorded externally after publication in `repository://stoquify/docs/blockers-docs/STOQ-X1-POL-004_ARTIFACT_HASH_MANIFEST_2026-08-31.json`
Activation status	`INACTIVE - AWAITING VALID SIGNATURES`

12. Acceptance statement

By approving this policy through the authoritative signature workflow, each signer confirms only the authority within that signer's documented appointment. The signers authorize the named service principals to perform the bounded, deterministic functions above for the stated non-production scope and validity period. They do not authorize human impersonation, production release, discretionary waiver or any function listed in Section 5.

Until the approval-system record, authority references, service-principal IDs, effective dates, signatures and final hashes are present and verified, this policy remains `DRAFT_UNSIGNED - NOT EFFECTIVE`.